

Individuell inlämningsuppgift

Workshop 2 - MITRE ATT&CK och hotanalys

Syfte

Denna individuella inlämningsuppgift följer upp Workshop 2 och tränar förmågan att använda MITRE ATT&CK, TTP, defensiv hotanalys, attackkedjor, försvarsfrågor, källor, spårbarhet och koppling till projektarbete.

Viktig avgränsning

Uppgifterna ska användas för analys, dokumentation och försvar. Beskriv inte tekniska genomförandesteg för angrepp. Fokusera på vad ett säkerhetsteam behöver förstå, upptäcka, förhindra och följa upp.

Instruktion till studenten

- Uppgiften genomförs individuellt och lämnas in enligt lärarens instruktion i Canvas.
- Uppgiften täcker kursmål 1, 2, 6 och 11.
- Du får använda materialet från Workshop 2, MITRE ATT&CK, kursmaterial och egna anteckningar.
- Du får använda generativa AI-assistenter och AI-assisterade säkerhetsverktyg, dock ska du beskriva eventuell AI-användning och vad som kontrollerats manuellt.
- Fokusera på tydliga resonemang, spårbarhet och defensiv analys.
- Dina svar ska visa att du kan använda begreppen, inte bara återge definitioner.
- Om du är osäker: skriv vad du är osäker på och hur du skulle följa upp det.

Översikt

Del	Fokus	Uppgifter
Del 1	Förstå MITRE ATT&CK som analysramverk	1-4
Del 2	TTP: Tactic, Technique och Procedure	5-8
Del 3	Bygg en defensiv attackkedja	9-12
Del 4	Försvarsfrågor och Blue/Purple-perspektiv	13-16
Del 5	Källor, spårbarhet och kvalitet	17-20
Del 6	Koppling till backlog, sprint och Workshop 3	21-24

Del 1 - Förstå MITRE ATT&CK som analysramverk

Uppgift 1

Beskriv med egna ord vad MITRE ATT&CK används till i ett säkerhetsteam.

Svarsinstruktion: Skriv 150-250 ord. Fokusera på analys, språk, struktur och försvarsperspektiv.

Enligt MITREs hemsida kan ett säkerhetsteam använda MITRE ATT&CK för att upptäcka tekniker som en angripare använder, hjälpa till att strukturera och analysera hot, emulera (efterlikna) attacker, och hjälpa organisationen att fatta beslut om till exempel vilka verktyg de vill använda.

Deras matris beskriver många kända sätt (TTP:er, Taktiker/Tactics, Tekniker/Techniques och Procedure/Procedures) för en hotaktör att samla data och information, att genomföra ett intrång, vad angriparen kan försöka göra när de tagit sig in, och vad slutmålet kan vara.

Matrisen innehåller även mitigerande åtgärder för varje listad taktik och teknik. Detta kan säkerhetsteamet använda sig av för att härda organisationens system och nätverk. Organisationens använder sig kanske inte av wifi (MITRE T1669) och behöver då inte mitigera det (MITRE M1041). Däremot är andra mitigeringar som rekommenderas för wifi-nätverk fortfarande relevanta för trådbundna nätverk.

MITRE skriver på hemsidan att matrisen inte är fulltäckande, men den tar upp många saker och mitigerar man majoriteten av de relevanta delarna bör organisationen vara väl skyddad enligt mig. Databasen uppdateras två gånger varje år. Då läggs nya tekniker till och information om tekniker som man lärt sig mer om redigeras.

Uppgift 2

Förklara varför ATT&CK inte ska användas som en checklista för att "göra attacker".

Svarsinstruktion: Skriv 150-250 ord. Beskriv skillnaden mellan analysramverk och angreppsinstruktion.

MITRE ATT&CK är ett (analys)ramverk som beskriver tekniker som en angripare kan tänkas använda. Ramverket är strukturerat och teknikerna kategoriserade för att vara lätta att hitta och för att vi lättare ska kunna se var de hör hemma i en attackkedja. Vi kan använda MITRE ATT&CK till att förstå hur teknikerna fungerar, och hur de används av en angripare. När vi förstått det så kan vi använda oss av de mitigerande åtgärder som föreslås i varje teknik.

MITRE ATT&CK är inte en angreppsinstruktion. Ramverket beskriver vad som händer och hur, men det finns inga instruktioner i teknikerna för hur man använder teknikerna i en attack. Vill man lära sig hur teknikerna används får man gå någon annanstans, men det finns gott om onlinekurser i etiskt hackande.

Det är ingen checklista som säger att om man kryssar i över hälften av punkterna så är man säker. En riktig angripare följer inte checklistor utan är kreativa och försöker hitta hål på andra sätt. Vi ska använda ramverket som referens i hotmodellering, inte en lista med punkter som vi går igenom en och en.

Uppgift 3

Välj fem tactics från Enterprise Matrix och beskriv vad varje tactic betyder på en övergripande nivå.

Svarsinstruktion: Använd egna ord. Undvik tekniska genomförandedetaljer.

- Reconnaissance
Olika sätt för en angripare att inskaffa information som de kan använda i senare skede.
- Resource Development
Olika sätt för en angripare att bygga upp infrastruktur och skaffa tillgång till system som grund för senare aktiviteter.
- Initial Access
Hur en angripare får in en fot i ett nätverk eller system. Här kan angriparen använda sig av den information och infrastruktur den fått tillgång till i de första taktikerna.
- Persistence
Beskriver hur angriparen behåller tillgången till system eller nätverk även om systemen startas om och inloggningsuppgifter (credentials) ändras.
- Stealth
Hur angriparen håller sig dold när den är inne i systemen.

Uppgift 4

Beskriv hur ATT&CK kan stödja kommunikationen mellan red team, blue team och ledning.

Svarsinstruktion: Skriv 200-300 ord. Ta upp gemensamt språk, spårbarhet och prioritering.

Källor: Utbildningens material, [Bitsight-artikel](#)

Gemensamt språk

Red Team (RT) tar sig in i systemet med en sårbarhet. Blue Team (BT) vill förstå vad som hände. RT kan då peka på vilken teknik som använts, och BT kan se vad som påverkats och hur de kan mitigera sårbarheten. Ledningen i sin tur behöver inte lära sig avancerad nätverksteknik för att få en övergripande bild av vad som har hänt. Alla tre grupperna kan läsa om teknikerna i MITRE ATT&CK och även om ledningen inte alltid har samma tekniska kompetens som teamen så är teknikerna förklarade med ett relativt enkelt språk.

Spårbarhet

RT kan testa en specifik teknik, och därefter följa upp med BT om tekniken upptäckts, om systemet larmat, eller om den missats helt. Därefter kan BT säkra upp om det behövs och RT kan testa tekniken igen, och även andra tekniker för att säkerställa att det BT gjort inte öppnat upp någon ny sårbarhet.

Prioritering

Ledningen förstår som sagt inte (alltid) de tekniska delarna i det säkerhetsteamens gör. Däremot förstår de om något kostar företaget pengar och resurser, och vill ha en säker och mindre utsatt organisation. MITRE är ett ramverk som är tydligt uppbyggt, visar täckning, och är lätt att förstå. Om säkerhetsteamet kan hålla sig på en lite lägre teknisk nivå i kommunikationen med ledningen så har ledningen lättare att planera och prioritera arbetet.

Del 2 - TTP: Tactic, Technique och Procedure

Uppgift 5

Förklara skillnaden mellan tactic, technique och procedure.

Svarsinstruktion: Använd ett eget defensivt exempel. Håll dig på konceptuell nivå.

Palo Alto

Tactic

Taktiken beskriver varför någon använder en viss teknik. Taktiken säger vad en angripare vill uppnå och vad säkerhetsteamet vill skydda mot. Det kan vara att få/läcka information, att få/läcka tillgång till nätverk, att dölja sig själv när man har fått tillgång/inte upptäcka en inkräktare, och insamling/hindra insamling av data. Dessa saker är olika mål som kräver olika taktiker.

Technique

De specifika teknikerna som hör till varje taktik. Om en angripare vill samla information om ett mål kan den till exempel phisha en användare, eller skanna ett osäkert nätverk. Det är olika tekniker, men kan leda till samma resultat. Om taktiken är målet, så är tekniken metoden.

Procedure

Procedure beskriver bland annat vilka verktyg som använts, och hur angripare har använt teknikerna. Det är hur tekniken använts i praktiken.

Exempel

Ett exempel vore en angripare som börjar planera ett angrepp. Det första steget är informationssamlande, som hör till taktiken Reconnaissance. Det finns flera olika sätt att göra det. Phishing (som jag använder som exempel hela tiden), nätverksskanningar, sökningar i databaser med stulen data och indentitetssökningar är exempel på tekniker som kan användas. Säkerhetsteknikerna läser igenom matrisen, ser att det är några av sårbarheterna de har. De kan gå igenom varje teknik och utföra de rekommenderade mitigerande åtgärderna. För att skydda sig mot phishing rekommenderas träning för användare, och mjukvara som hindrar spoofing och liknande.

Uppgift 6

Skapa en TTP-förklaring för tre valfria ATT&CK-tekniker.

Svarsinstruktion: För varje teknik: skriv tactic, technique och en kort procedure-beskrivning utan operativa instruktioner.

Phishing For Information (igen)

Tactic: Reconnaissance

Technique: T1598

Procedure: En angripare skickar ett mail till någon i en organisation i syfte att få fram information om målet. Mailet måste vara välformulerat så att mottagaren tror att det är säkert att röja informationen, och det måste skickas till någon som faktiskt vet något om det.

Account Manipulation

Tactic: Persistence, Privilege Escalation

Technique: T1098

Procedure: I ett dåligt konfigurerat system eller om en angripare lyckas få tillräckligt hög behörighet kan angriparen ändra sitt eller andras konton för att säkerställa att kontot har tillgång till systemet om något ändras, eller att få tillgång till fler delar av nätverket. Ett exempel som MITRE tar upp är att ändra livslängden för ett konto.

Audio Capture

Tactic: Collection

Technique T1123

Procedure: Med hjälp av malware eller skript kan en angripare få mikrofoner att spela in ljud från en organisation i syfte att samla in information.

Uppgift 7

Välj en tactic och identifiera tre tekniker som kan höra hemma inom den.

Svarsinstruktion: Motivera varför teknikerna passar in i tacticen.

Tactic: Defense Impairment

Technique: Disable or Modify System Firewall, T1686

Varför: Att använda ett uppkopplat system utan en brandvägg är väldigt riskabelt i största allmänhet. Om en angripare gör det utifrån betyder det även att man redan är en måltavla, och man måste täppa till hålet som brandväggen lämnar efter sig innan den som stängde av eller ändrade utför en större attack eller läcker informationen till någon som i sin tur utför attacken. Men tekniken hör definitivt till taktiken att försvaga försvaret.

Technique: Downgrade Attack, T1689

Varför: Downgrade Attack innebär att man utnyttjar bakåtkompabilitet i ett system för att tvinga det att använda gamla och mindre säkra lägen. Det försämrar skyddet, då detta kan stänga av nyare försvarsmetoder och tillåta att angripare använder gamla buggar och sårbarheter som patchats bort i nyare uppdateringar.

Technique: Modify Cloud Compute Infrastructure, T1578

Varför: Denna teknik innebär att en angripare ändrar i molnet. De kan tänkas skapa, ändra eller radera virtuella maskiner och backuper (snapshots, så stillbilder på fungerande konfiguration). Om de lyckas radera komponenter kan de dölja sin närvaro när säkerhetsteamet letar efter spår senare. Försvarsförmågan sänks till exempel om angriparen lyckas stänga av loggning och övervakningsmetoder, eller ändra i grupper.

Uppgift 8

Beskriv varför det kan vara svårt att mappa en observation till rätt teknik.

Svarsinstruktion: Ta upp osäkerhet, kontext, datakvalitet och behov av källor.

En teknik kan höra till flera taktiker. Access Token Manipulation hör till exempel till både Stealth och Privilege Escalation. Det finns även tekniker som bara hör till en taktik men som jag personligen tycker kunde höras till fler. Mitt exempel på det är Social Engineering. Den finns bara i Stealth, och jag anser att den även kunde höras till Reconnaissance. Därför är det viktigt att komma ihåg att MITRE ATT&CK inte är en enkel checklista.

Men det blev lite sidospår.

Datakvalitet: Loggarna kan vara ofullständiga eller inte logga allt som säkerhetsteamet önskar. Om det inte finns loggar på vad användarna skrivit i terminalen kan det vara svårt att veta vad som faktiskt hänt, och vad vem har gjort. Säkerhetsteamet kan se att någonting har hänt, men kan sakna information om vad och hur.

Kontext: En del tekniker använder sig av verktyg som redan finns installerade. Att någon öppnar terminalen eller PowerShell säger inte så mycket i sig själv. Man måste kolla vem det var och när, och om det är ovanligt att personen gör detta vid den tiden.

Osäkerhet: Olika tekniker kan resultera i liknande spår. Om någon får ett phishing-mail kan man inte omedelbart veta om det är för att få information, att få tillgång till nätverket, eller för att kunna flytta sig i nätverket.

Behov av källor: Bara en enskild logg (eller annan datakälla) ger sällan en full bild av vad som har hänt. En anställd i organisationen kanske bara har loggat in från arbetsplatsen tidigare, men plötsligt larmar systemet att personen loggar in utifrån. Säkerhetsteamet vet inte automatiskt om personen bestämt sig för att jobba hemifrån en dag, eller om det är någon som fått tillgång till personens inloggningsuppgifter.

Del 3 - Bygg en defensiv attackkedja

Uppgift 9

Bygg en enkel attackkedja med 3-5 steg.

Svarsinstruktion: Använd tactics som etiketter. Syftet är analys och försvar, inte teknisk genomförandeinstruktion.

Jag läste fel dokument när jag gjorde uppgiften så punkt 1 och punkt 5 är tillagda i efterhand när jag trodde att jag var klar. Det kan skilja i hur jag har skrivit om punkterna i den här uppgiften och i senare uppgifter.

Gjort i grupp:

TTP-beskrivning:

1: Taktiken är Reconnaissance och tekniken är Phishing for information. Angriparen kontaktar någon i organisationen och försöker få den personen att ge ut information. Försvaret bör träna användare i att upptäcka social engineering.

Källa: MITRE T1598.

2: Taktiken är Initial Access och tekniken är Phishing. Angriparen skickar ett falskt mejl med en skadlig bilaga för att få åtkomst till organisationens system. Försvaret bör undersöka om mejlet kan upptäckas och blockeras. Källa:

MITRE T1566.001.

3: Taktiken är Execution och tekniken är User Execution. Användaren öppnar bilagan, vilket gör att angriparens kod kan köras på datorn. Försvaret bör kontrollera om sådan aktivitet kan upptäckas. Källa: MITRE T1204.002.

4: Taktiken är Discovery och tekniken är Network Service Discovery. Angriparen skannar nätverket för att hitta datorer, servrar eller ICS-system. Försvaret bör övervaka ovanlig scanning i nätverket. Källa: MITRE T1046.

5: Taktiken är Lateral Movement och tekniken är Taint Shared Content. Angriparen lägger in skadlig kod i filer på delade utrymmen i nätverket i hopp att andra grupper med tillgång till filerna och andra behörigheter öppnar filerna och kör koden. Antivirus och liknande mjukvaror kan upptäcka koden. Skrivrättigheter i mapparna bör vara restriktivt.

Källa: MITRE T1080.

Uppgift 10

Beskriv varje steg i er kedja med “varför”, “hur” och “vad såg vi?”.

Svarsinstruktion: Koppla till TTP-modellen: tactic, technique och procedure.

Reconnaissance, Phishing For Information

Varför (tactic): Angriparen letar efter svagheter i försvaret, vägar in och personer som hanterar känsliga personuppgifter på potentiellt riskabelt sätt.

Hur (technique): Genom att skicka mail och ställa frågor om organisationen och hoppas få svar på mer än vad de frågar.

Vad såg vi (procedure): Avsändare som inte hade någon anknytning till organisationen som ställde frågor eller länkar som ber användare svara på enkäter och formulär.

Initial Access, Phishing

Varför (tactic): Angriparen vill komma in i organisationens nätverk utan att behöva bryta sig igenom starka brandväggar.

Hur (technique): Genom att skicka ett riktat email som innehåller en bilaga med skadlig kod och få mottagaren att öppna den.

Vad såg vi (procedure): Loggar visade ett mail från en extern avsändare. Mailet hade en bifogad fil. Systemet flaggade för en avvikande avsändare och en misstänkt bifogad fil.

Execution, User Execution

Varför: Angriparen vill att deras medskickade skadliga kod exekveras på måldatorn.

Hur: Lura användaren att öppna den bifogade filen, till exempel genom att få den att se ut som en viktig pdf.

Vad såg vi: Ett program som kan läsa pdf:er öppnar en underprocess, som PowerShell eller CMD. Det är inte normalt beteende. Vad vi ser efter det beror på vad koden är skriven för att göra.

Discovery, Network Service Discovery

Varför: När angriparen har tagit sig in i systemet vill den kartlägga nätverket för att hitta sårbarheter.

Hur: Angriparen använder någon sorts skanningsverktyg för att leta efter öppna portar och sårbara tjänster på nätverket.

Vad såg vi: Brandväggsloggar och nätverksloggar upptäckte ovanligt många anslutningsförsök på en kort tid från en enskild klient.

Lateral Movement, Taint Shared Content

Varför: Angriparen vill flytta sig i nätverket för att få tag i andra behörigheter, resurser och data.

Hur: Filer i delade mappar på nätverket infekteras med kod som automatiskt öppnar vägar till användare som öppnar filerna.

Vad såg vi: Loggarna talade om att en fil i en delad mapp ändrades eller skapades, och kort därefter larmade andra användares system om skadliga skript eller processer i samband med att filen öppnades.

Uppgift 11

Identifiera vilka steg i attackkedjan som är mest osäkra.

Svarsinstruktion: Beskriv vad ni behöver veta mer om för att göra analysen bättre.

Uppgiften besvarades innan jag upptäckte att jag hade missat två steg i kedjan. Med de tillagda stegen är det mer troligt steg ett, Phishing For Information, som är den mest osäkra. Organisationer får mail från alla möjliga håll, och det går inte se att ett visst mail från någon som inte har någon med organisationen att göra är misstänkt. Det är lite lättare om det kommer mail med länkar till enkäter eller formulär, om man i förväg vet att tjänsten där enkäten/formuläret skapats på har använts på ett misstänkt sätt tidigare. Men väldigt många har länkar i sina mailsignaturer, och försvaret vill inte att alla mail flaggas för ingenting.

Det mest osäkra är steg två i vår kedja, User Execution. Vi kan se att någonting avvikande har hänt (PowerShell eller CMD startas) men vi kan i det här läget inte se vad den skadliga koden försökte göra, om koden kördes klart, eller om den stoppades av några skydd i systemet, som antivirus.

Även i steg ett, Phishing, är vi osäkra, då vi inte vet säkert om användaren har öppnat mailen, öppnat filen, eller om koden kördes direkt när mailet öppnades. Eller ännu värre, om angriparen hittat ett sätt att köra koden automatiskt när mailet tagits emot.

Vad vi behöver veta:

Vilka kommandon som kan ha exekverats. Vi behöver veta vad koden försökte göra.

Om några filer ändrats eller skapats efter att koden kördes.

Vilket konto som utförde skanningarna eller nätverksanslutningarna i steg tre för att utesluta att det gjordes manuellt av användaren av någon anledning.

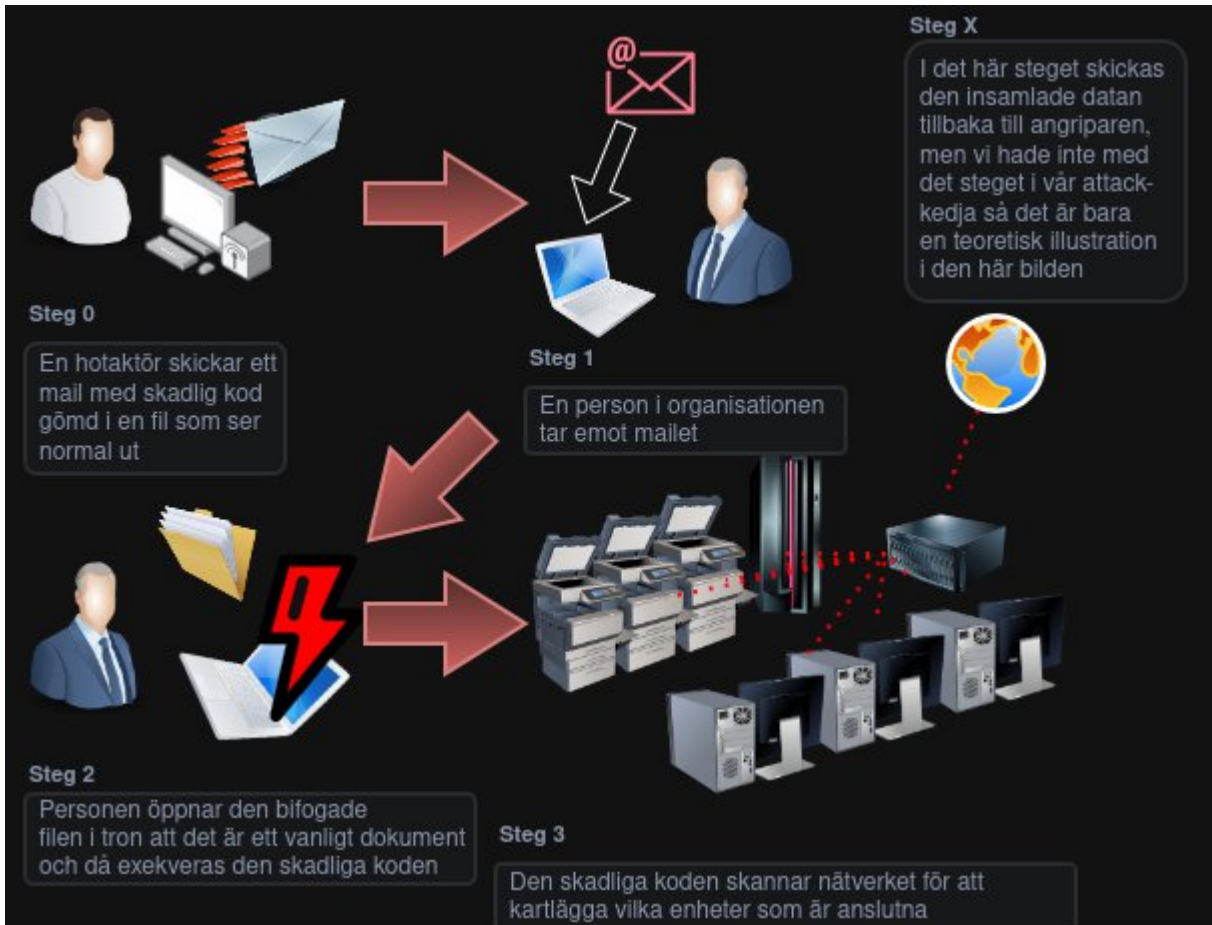
Om mailet var väntat, och om det rapporterades som misstänkt någonstans under tiden.

Uppgift 12

Rita eller beskriv attackkedjan som en enkel kedja från första kontakt till påverkan.

Svarsinstruktion: Använd pilar och korta rubriker. Om ni skriver digitalt kan ni använda tabell eller punktlista.

Jag gjorde den här bilden på Drawio innan jag upptäckte att jag hade gjort fel. Är nöjd med den så den får vara kvar. Men Steg X blir istället Lateral Movement, där delade filer infekteras.



Del 4 - Försvarsfrågor och Blue/Purple-perspektiv

Uppgift 13

Formulera minst en försvarsfråga per steg i attackkedjan.

Svarsinstruktion: Exempel: Hur skulle detta kunna upptäckas? Vilken signal, rutin eller kontroll kan vara relevant?

Från vårt grupparbete:

1. Phishing For Information: Är användare tränade på att upptäcka social engineering och att inte klicka på misstänkta länkar? Relevanta signaler är externa enkäter och formulär.
2. Phishing: Kan vi upptäcka och blockera falska mejl och skadliga bilagor? Relevanta signaler är misstänkta avsändare, bilagor och länkar.
3. User Execution: Kan vi upptäcka när en användare öppnar en skadlig fil och kod börjar köras? Relevanta loggar är filöppning, processskapande och eventuell start av PowerShell.
4. Network Service Discovery: Kan vi upptäcka om en dator skannar många IP-adresser eller portar i nätverket? Relevanta signaler är många anslutningsförsök och scanning mellan IT- och OT-nätverk.
5. Taint Shared Content: Vilka har skrivrättigheter till delade mappar? När ändrades filen senast och varför? Behöver användare tillgång till filen över huvud taget eller kan den tas bort? Signaler är larm från antivirus och anti-malware kort efter att filen öppnats.

Uppgift 14

Välj två tekniker och resonera kring möjliga detektionssignaler.

Svarsinstruktion: Håll svaret på konceptuell nivå. Beskriv typer av signaler, inte tekniska exploit-steg.

Teknik: Valid Accounts (T1078)

Valid Accounts är en teknik där någon utifrån har lyckats få tillgång till helt legitima användarkonton. Det kan vara användare som är anställda eller inhyrda av organisationen, men det kan även vara gamla konton som inte hanterats rätt och fortfarande har rättigheter trots att användaren inte längre har någon anknytning till organisationen.

En signal för det kan vara att ett konto loggar in från en plats eller en IP som systemet inte känner igen, eller ett land som systemet inte tillåter att man loggar in från utan vidare. Ett exempel som jag tror jag använt antingen i den här uppgiften eller i självstudierna (om jag inte tog bort det) var en arbetare som alltid jobbar på plats på ett företag men plötsligt loggar in från en helt okänd IP-adress.

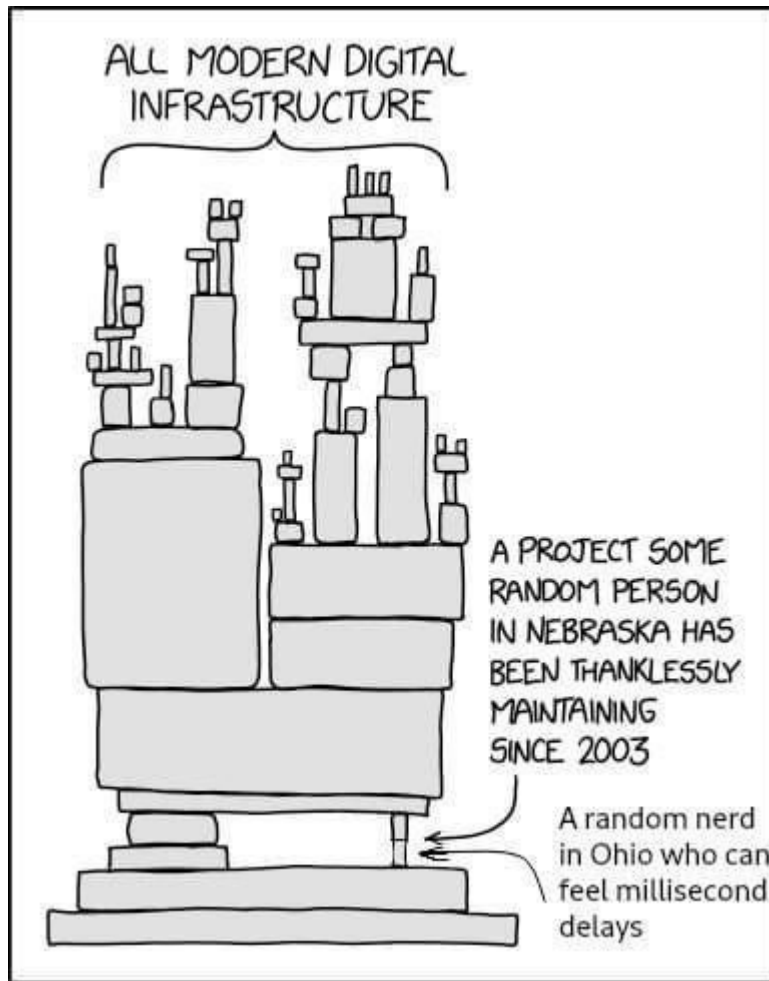
En annan signal man kan tänka sig är att en användare plötsligt börjar bete sig på ett ovanligt sätt. Användaren kanske skannar nätverket eller skickar trafik på ett sätt den inte har gjort innan. Användaren kan även försöka komma åt andra konton eller data den inte har behörighet till.

Om det är möjligt inom budget och resurser bör säkerhetsteamet hålla utkik efter båda sorterna av signaler i realtid för att upptäcka ett potentiellt intrång tidigt.

Teknik: Shared Modules (T1129)

Den tydligaste signalen jag har hittat för den här tekniken är ökad resursförbrukning. Det finns ett jättebra exempel från 2024, XZ Utils backdoor. Någon hade lyckats få in möjligheten att köra kod utifrån så länge man hade tillgång till en speciell privat nyckel. Det upptäcktes av Andres Freund när hans SSH-anslutningar använde oväntat mycket processorkraft.

Det krävs hög noggrannhet för att övervaka systemets resurser när det är så små skillnader det kan handla om. Det kan även handla om antingen spikar, eller knappt märkbar prestanda över en längre tid. Och säkerhetsteamet måste veta om prestandaändringen beror på en tjänst som någon i organisationen har startat, eller om det beror på något utifrån.



Uppgift 15

Välj två tekniker och resonera kring möjliga riskreducerande åtgärder.

Svarsinstruktion: Beskriv organisatoriska, tekniska eller processmässiga åtgärder.

Teknik: Brute Force (T1110)

Mitigerande åtgärd: Account Use Policies

Kan låsa kontot efter ett antal misslyckade försök att logga in för att hindra att någon lyckas gissa lösenordet. Det kräver en balans så att användare inte låser ute sig själva hela tiden samtidigt som någon utifrån inte får ha för många försök på sig att gissa. Åtgärden kan även hindra inloggningar om de inte är från vissa bestämda platser. Det är en bra åtgärd om den inte är för strikt eller för slapp, och den kan även användas som åtgärder för andra tekniker. Att sätta en policy för vilka IP-adresser som får ansluta borde stoppa en stor del skadlig trafik utifrån.

Mitigerande åtgärd: Multi-factor Authentication

Kräver att man visar vem man är på mer än ett sätt. Bara ett lösenord räcker inte. Man kan till exempel få använda sitt fingeravtryck, eller godkänna inloggningen i en app.

En väldigt användbar åtgärd. Den stoppar inte bara Brute Force utan kan stoppa angripare från att logga in efter att användarnamn och lösenord har läckt.

Man bör dock inte överdriva. Användare vill inte behöva skriva in lösenord, godkänna inloggningen i en app, och skriva in en kod som skickats i SMS bara för att man har tagit en timme lunch.

Mitigerande åtgärd: Password Policies

Kräver starka lösenord, att användare byter lösenord med jämna mellanrum, förbjuder återanvändande av lösenord. Åtgärden kan skydda mot läckta lösenord om användare byter tillräckligt ofta eller tvingas byta om en läcka misstänks.

Det kan vara besvärligt för användare med för många svåra lösenord, så det borde rekommenderas att använda en lösenordshanterare. Lösenordshanterare som är i molnet kommer med sina egna problem, så jag förespråkar personligen en lösenordshanterare som lagrar databasen med lösenord lokalt. Användaren måste fortfarande ha ett starkt lösenord till databasen eller sitt konto, och bör rotera lösenordet även där. Men det är bara ett lösenord att hålla reda på i taget.

Nackdelen med en sådan lösenordshanterare är att man ska låta bli att spara flera kopior av filen. Lokalt och på någon form av säker molnlagring räcker, men man ska inte ladda upp den på någon publik lagringsplats bara för att man tror att ingen kan knäcka ens lösenord. Om databasfilen läcker så kommer någon kunna ta sig in i den till slut, så innan det händer måste man gå igenom och byta lösenord på alla sparade inloggningsman har.

Men det var ett sidospår. Mitigeringen hjälper mot angrepp, men man får inte heller här vara för strikt i hur man utformar den.

Mitigerande åtgärd: User Account Management

Åtgärden handlar om ett kontos livscykel och least privilege. Det hör även ihop lite med de tre tidigare åtgärderna. Åtgärden säger att konton bara ska ha de behörigheter de behöver för att utföra sina roller (least privilege). Gå igenom konton regelbundet för att säkerställa att det inte ligger kvar gamla inaktuella behörigheter.

Konton ska ha starka lösenord enligt Password Policies ovan.

Konton ska låsas enligt Account Use Policies vid behov.

Konton ska använda sig av Multi-factor Authentication.

Åtgärden säger att inaktiva konton och konton utan ägare ska stängas av, gärna automatiskt efter en viss tids inaktivitet.

Den här mitigering åtgärden är i största del en samling av de tidigare. Följer man dem så följer man den här.

Teknik: Replication Through Removable Media

Mitigerande åtgärd: Behavior Prevention on Endpoint

Enligt MITRES databas är den här åtgärden en inställning i Windows 10, enable Attack Surface Reduction (ASR).

Jag vet inte säkert men jag gissar att inställningen går att göra i Windows 11 också. Den är tänkt att hindra att osignerade eller okända exekverbara filer inte får köras från USB-enheter.

I de flesta fall kanske det räcker, men jag har inte kunnat läsa mig till hur mycket det stoppar i praktiken. Flera skriptspråk är listade, och filtyper, men det står inget om språk och filer utöver det. Om man bara använder ASR så kommer antagligen någon ta sig förbi det på något sätt. Det skyddar dessutom bara Windows-system. Jag tror att Linux är byggt annorlunda så att tekniken inte går använda på samma sätt, men det skulle jag behöva läsa mer om.

Mitigerande åtgärd: Disable or Remove Feature or Program

Stäng av Autorun. Det är något inte bara organisationer och företag borde göra, utan alla som använder en Windows-dator.

Ta bort program som inte används. De är ofta inte patchade och kan ha okända sårbarheter.

Stäng av funktioner som inte används. Om användaren inte behöver Telnet så kan det vara avstängt.

Förhindra användare från att installera vilka program de vill. Hör ihop med CIS-kontrollen om tillåten mjukvara.

Säkerhetsteamet kan inte patcha eller ta bort ett sårbart program om de inte vet att en användare har installerat det. Det bör även gå att stänga av möjligheten för användare med lägre behörighet att installera mjukvara över huvud taget.

Ta bort tjänster som inte behövs. Samma som med funktioner och program. Att ta bort dessa minskar attackytan.

Begränsa add-ons och plugins. Användarna kanske blir sura när de inte får kolla på Twitch med FrankerFacez och BTTV påslagna på arbetstid, men i det läget har det kanske gått för långt av andra skäl.

Den här mitigering åtgärden är till för att begränsa attackytan. Just fler tjänster och program som ligger och körs i bakgrunden utan att användas, desto högre risk är det att någonting har en sårbarhet som organisationen inte haft

möjlighet att patcha bort. I en organisation bör det bara finnas den mjukvara och de konfigurationer som användarna behöver för att utföra sina jobb.

Mitigerande åtgärd: Limit Hardware Installation

Den här åtgärden har jag varit med om i verkligheten. På en tidigare praktikplats var det förbjudet att koppla in USB-enheter i datorerna. Skulle vi ladda telefonerna fick vi inte använda datorn, utan var tvungna att ladda via eluttaget. Vi fick inte heller sätta in några USB-stickor i datorerna, och vi fick vara försiktiga med tangentbord och möss som kunde ha något minne i sig.

USB går att stänga av på en mjukvarunivå, så att systemet inte läser av någon data därifrån. I beskrivningen på åtgärden står det även att det ska finnas starka lösenord till BIOS/UEFI, så jag antar att det går att stänga av nära hårdvaran också.

Det är en bra åtgärd. Vi har sett roliga exempel på människor som lagt in skadlig kod i vad som ser ut att vara en vanlig USB-kabel, men som är ett förklätt USB-minne. På min praktik fick jag även instruktioner om att inte sätta in USB-minnen jag hittar på gatan i någon dator. På praktiken skulle jag lämna in det till säkerhetsteamet. Jag hittade aldrig något minne, men nu vet jag att jag inte ska sätta in något sånt i min dator hemma.

Uppgift 16

Beskriv hur ett säkerhetsteam kan använda en attackkedja för att förbättra sitt försvar.

Svarsinstruktion: Skriv 200-300 ord. Ta upp lärande, prioritering och uppföljning.

En attackkedja visar vilka tekniker en angripare använt. I den bästa av världar har säkerhetsteamet tittat igenom matrisen, analyserat vilka tekniker som är relevanta för organisationen, och därefter kommit fram till vilka tekniker som är viktigast att fokusera på. Säkerhetsteamet kan då se vilka tekniker som kan användas efter varandra och vilka som inte kan användas efter varandra. Ett exempel på det senare kan vara att en angripare fysiskt tar sig in i ett isolerat produktionsnätverk utan internetanslutning, där de inte enkelt kan få ut data via en extern uppkoppling.

Om säkerhetsteamet inte har haft möjlighet att se över matrisen så kan de fortfarande använda den genom att gå igenom vad som har hänt, identifiera teknikerna som har använts, och använda mitigering åtgärder för att samma incident inte ska inträffa igen.

Matrisen gör det lättare för säkerhetsteamet och ledningen att följa upp incidenter och planerade åtgärder. När säkerhetsteamet identifierat en risk kan de planera in åtgärder, som de sedan kan presentera för organisationen. För att använda attackkedjan vi satte ihop i gruppen, så är första steget phishing. Vi tänker oss att säkerhetsteamet kan se att det redan har hänt, eller att risken finns att det händer. De läser på om tekniken, och vilka mitigering åtgärder som är rekommenderade. Om risken för phishing är tillräckligt hög, vilket den ofta är, behöver åtgärder genomföras även om de kan påverka organisationens arbetsflöde. Antivirus kan påverka arbetet men relativt lite, men att blockera innehåll online kan riskera att störa mer. Man får även tänka på att användare kan bli irriterade av en sådan åtgärd. Även att träna användarna att förstå phishing kan påverka och ta tid från arbetet.

Nästa steg i vår kedja är User Execution. Säkerhetsteamet kanske anser att åtgärderna mot phishing är tillräckliga, och risken är närmast eliminerad. Men då måste man tänka på vad som händer om phishing ändå inträffar och någon kommer åt systemet. Dessutom finns det andra sätt att ta sig in och få användare att köra kod. Därför bör även denna tekniken hanteras och åtgärdas. Samma tanke sätt bör användas på det tredje steget. Bara för att man åtgärdar en risk i början av en kedja betyder inte det att riskerna senare åtgärdas av sig själva.

Del 5 - Källor, spårbarhet och kvalitet

Uppgift 17

Dokumentera vilka källor ni använder i er ATT&CK-analys.

Svarsinstruktion: Skriv minst tre källor eller länkar. Beskriv kort vad varje källa bidrar med.

MITRE ATT&CK

MITRE skapade både CVE-systemet (Common Vulnerabilities and Exposures) och matrisen vi använt hittills i kursen.

CVE

Databas med "över 366000" sårbarheter.

CIS-kontroller

En kravlista med de viktigaste säkerhetsåtgärderna en organisation bör genomföra för att minska de vanligaste riskerna.

NIST Cybersecurity Framework

Standard för hur en organisation hanterar risk och säkerhet.

NIS2

Nytt regelverk. Till skillnad från de andra är det här lagkrav och inte bara ett ramverk.

Uppgift 18

Beskriv hur ni säkerställer att er TTP-mappning är rimlig.

Svarsinstruktion: Ta upp källa, motivering, osäkerhet och gruppgranskning.

Vi använder oss av säkra källor, som MITRE ATT&CK, CVE och NIST, och innan vi anser mappningen färdig kollar vi att tekniker stämmer överens med hur angripare beter sig i verkligheten. Som källa har stora organisationer inom cybersäkerhet högre trovärdighet än en blogg från 2016.

Varje teknik, taktik och procedur motiveras enligt den utvärdering vi gjort av vad som är relevant för organisationen och den prioritering vi gjort.

Osäkerhet innebär att inget ramverk är helt fulltäckande, och vi är bara människor. Vi kan vara sårbara för tekniker som vi inte tänkt på, och en angripare kan göra någonting som inte är beskrivet i de ramverk vi använder. Därför är det viktigt att vi tänker utanför lådan så mycket som möjligt och hellre täcker upp för någonting relativt onödigt än att vi inte täcker upp tillräckligt.

Gruppen består av individer med olika erfarenheter och kompetenser, och alla kan bidra med någonting. Om en person inte tänker på en viss teknik så kanske nästa person tänker på tekniken direkt.

Uppgift 19

Skapa en mini-Definition of Done för en färdig hotanalys.

Svarsinstruktion: Lista minst fem kriterier. Kriterierna ska gå att använda av hela gruppen.

Den ursprungliga DoD vi hade efter workshop 1:

- Presentationsklar
- Innehåller relevanta delar
- Skriftlig dokumentation på vad som är gjort
- Majoritet av gruppen har godkänt

Ny DoD specifikt för hotanalys:

- Kompletta attackkedja, från början till slut. 3-5 steg är rimligt, eventuellt fler för större hot.
- Relevant till försvar. Minst en försvarsfråga, förslag på mitigerande åtgärder.
- Källhänvisning. Använd de källor vi kommit överens om. Undvik andra källor utan diskussion med resten av gruppen.
- Så fullständig skriftlig dokumentation som möjligt. Strukturerat och läsbart även för de med mindre teknisk kompetens.
- Hantera osäkerhet. Motivera antaganden som gjorts på grund av brist på data.
- Gruppgranskning innan godkännande. Misstag och fel ska tas upp och åtgärdas.

Uppgift 20

Beskriv vad som gör en hotanalys användbar för någon annan än den som skrev den.

Svarsinstruktion: Skriv 150-250 ord. Fokusera på tydlighet, spårbarhet och mottagare.

En hotanalys blir användbar för någon annan än den som skrev analysen om någon annan kan gå in och ta över analysen och sätta in sig i den utan stora problem. Hotanalysen måste vara fullständigt dokumenterad från början. Det ska inte finnas några otydligheter vad den första analytikern menar. Källorna ska vara dokumenterade och motiverade. Den nya analytikern ska kunna följa tankegångarna, förstå varför tekniker och procedurer har valts, vilken källa som använts, om data saknats och varför i så fall ett visst antagande har gjorts. Analysen måste tydligt visa vad som är fakta och vad som är antaganden.

För att en hotanalys ska vara tydlig och enkel behöver man även ta bort överflödiga och mindre relevant information. Analysen ska bara innehålla information som bidrar till förståelse. Samtidigt vill man inte missa någonting som kan vara viktigt eller bra att ha med. Det kan vara en bra idé att visa vilka tekniker man utesluter så att nästa tekniker vet om det och inte dubbelarbetar och går igenom samma tekniker igen.

Analysen måste vara tillräckligt detaljerad och komplex för att andra tekniker ska kunna förstå den, samtidigt som den måste vara enkelt skriven och förklarande för att ledningen kan förstå den, så att de kan ta beslut om hur organisationen ska prioritera resurser och planera arbetet.

Del 6 - Koppling till backlog, sprint och Workshop 3

Uppgift 21

Uppdatera er backlog baserat på det ni upptäckte i Workshop 2.

Svarsinstruktion: Skriv minst fem nya eller ändrade backlog items. Ge kort motivering.

- Utöka vår Definition of Done
Fler punkter och mer tydlig.
- Dela backlog item om inventering i två
Dels "Lista organisationens tillgångar" och "Sammanställ en lista på godkända mjukvaror". Tidigare var båda samlade i en backlog item, men de har olika prioriteringar och bör vara två olika.
- Skapa en checklista inför workshop 3
Enligt mall på Canvas. Strukturerad lista på vad som bör vara klart innan.
- Skapa en TTP-tabell
Enligt mall på Canvas. Förberedelse för det riktiga projektet.
- Planera nästa steg
Underlätta prioritering.

Uppgift 22

Beskriv hur er attackkedja förhåller sig till ert Sprint Goal.

Svarsinstruktion: Är sprintmålet fortfarande relevant? Behöver något justeras?

Vår sprint handlade om att få ihop ett arbetssätt och bestämma gruppens roller. Attackkedjan var bra träning inför projektet vi ska hantera senare i kursen då vi kan sammanställa en för projektet relevant attackkedja på samma sätt.

Uppgift 23

Formulera minst två uppföljningsfrågor inför Workshop 3.

Svarsinstruktion: Frågorna ska kunna användas vid review eller retrospektiv.

Om man skapar en attackkedja där en teknik är högt prioriterad, men de andra är lägre prioriterade, ska man då åtgärda alla delar i kedjan, eller den högst prioriterade och sedan åtgärda andra tekniker som är högt prioriterade men inte i kedjan?

Ska man anpassa en rapport eller liknande till mottagaren eller göra den lätt att förstå oavsett teknisk kompetens från början?

Har vårt arbetssätt fungerat bra, eller måste vi ändra någonting för att det ska fungera bättre?

Har vi nått vårt mål? Om inte, vad har gått snett? Vad behöver vi justera?

Uppgift 24

Förbered en kort statusrapport till Workshop 3.

Svarsinstruktion: Skriv 5-7 punkter: vad ni gjorde, vad som blev klart, vad som är oklart och vad ni vill ändra.

Vad gick bra?

- Mötesplanering
- Mötesdeltagande
- Det var väldigt smidigt att skapa Kanban-board
- Smidigt och användarvänligt att göra checklistor.

Vad blev svårt?

- Vi skulle ha velat veta mer om vad projektet ska vara för att kunna jobba efter det.
- Vi hade gärna fått en demonstration på det agila arbetet, hur man gör i praktiken.
- Svårt att hitta information som svar på frågorna. Exempel, var är beskrivningarna på analysramverk och angreppsinstruktion enligt MITRE ATT&CK?

Vad behöver vi ändra?

- Vi kom inte på något. Saker har fungerat bra från vårt håll.

Vad tar vi med oss till nästa workshop?

- Fundera mer på om det finns något vi behöver ändra på.
- Ställ mer frågor till utbildaren.

Frivillig fördjupningsutmaning

Skapa en komplett mini-hotanalys baserad på din Workshop 2-kedja.

Inkludera: mål med analysen, attackkedja, TTP-tabell, försvarsfrågor, källor, osäkerheter, uppdaterad backlog och förslag till nästa sprint. Max tre sidor.

Rekommenderade referenser

- MITRE ATT&CK: <https://attack.mitre.org/>
- MITRE ATT&CK Enterprise Matrix: <https://attack.mitre.org/matrices/enterprise/>
- CISA - Best Practices for MITRE ATT&CK Mapping: <https://www.cisa.gov/news-events/news/best-practices-mitre-attckr-mapping>
- MITRE ATT&CK Data & Tools: <https://attack.mitre.org/resources/attack-data-and-tools/>

Bedömningskriterier

Bedömningen fokuserar på analysförmåga, begreppsanvändning, spårbarhet, defensivt perspektiv och koppling till projektarbete.

Matrisen är formulerad med kursens nivåer Godkänt (G) och Väl godkänt (VG). Den mellersta kolumnen beskriver kvaliteter som stärker bedömningen inom godkänd nivå och kan användas som stöd i återkoppling.

Bedömningsområde	Grundläggande krav för G	Tydliga kvalitetskännetecken	Kvalitetskännetecken för VG
Förståelse för MITRE ATT&CK	Kan beskriva ATT&CK på en grundläggande nivå och visar förståelse för ramverkets syfte.	Förklarar ATT&CK med egna ord och kopplar ramverket till hotanalys och säkerhetsarbete.	Visar fördjupad förståelse för ATT&CK som analysramverk och resonerar kring styrkor, begränsningar och användningsområden.
TTP-förståelse	Kan identifiera tactic, technique och procedure samt beskriva skillnaden översiktligt.	Använder TTP-begreppen konsekvent och förklarar sambanden mellan dem.	Använder TTP som ett naturligt analysverktyg och kan motivera val samt alternativa tolkningar.
Attackkedjor	Har skapat en enkel attackkedja där stegen följer en logisk ordning.	Attackkedjan är väl motiverad och sambanden mellan stegen förklaras.	Analysen visar systemsyn och används för att resonera kring risker och försvarsperspektiv.
Försvarsfrågor	Har formulerat relevanta försvarsfrågor.	Försvarsfrågorna är välformulerade och kopplas till upptäckt, begränsning eller uppföljning.	Kopplar angriparbeteenden till flera möjliga försvarsperspektiv och resonerar kring prioritering.
Källor och spårbarhet	Anger källor och referenser till analysunderlaget.	Motiverar hur källorna används och visar förståelse för spårbarhet.	Reflekterar kring källornas styrkor och begränsningar och håller hög dokumentationskvalitet.
Projektarbete	Har uppdaterat backlog eller projektunderlag.	Kopplar analysen till Sprint Goal, backlog eller Definition of Done.	Visar hur analysen skapar värde i projektet och resonerar kring prioritering, risk och nästa steg.

Samlad bedömning

Godkänt (G)

Studenten har genomfört huvuddelen av uppgifterna, visar grundläggande förståelse för ATT&CK, kan beskriva en enkel attackkedja, kan formulera relevanta försvarsfrågor och kan dokumentera sitt arbete.

Väl Godkänt (VG)

Studenten visar god analytisk förmåga, använder ATT&CK och TTP konsekvent, motiverar sina slutsatser, identifierar osäkerheter, visar god förståelse för försvarsperspektivet och kopplar analysen till projektets mål och arbetssätt.